

Audit SSI

Chapitre 2 : Gouvernance des SI, de la sécurité des SI et cadre organisationnel

1. La gouvernance des systèmes d'information

La **gouvernance des SI** désigne l'ensemble des **structures, processus, rôles et mécanismes** mis en place pour **aligner les systèmes d'information avec les objectifs stratégiques de l'organisation**, tout en assurant leur **maîtrise, sécurité et performance**.

Principes clés :

- Alignement stratégique des SI sur les objectifs métiers.
- Utilisation efficace et efficiente des ressources SI.
- Gestion des risques liés aux SI.
- Conformité légale et réglementaire.
- Mesure des performances et amélioration continue.

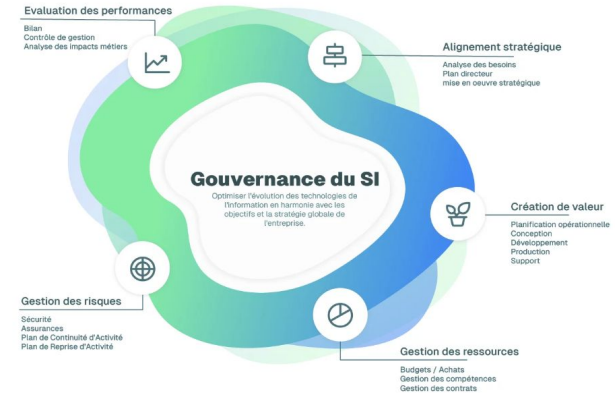


1. La gouvernance des systèmes d'information

Autrement dit, la gouvernance SI cherche à répondre à trois grandes questions :

- Les SI contribuent-ils à **créer de la valeur** pour l'organisation ?
- Les **risques liés à l'usage des technologies** sont-ils identifiés et maîtrisés ?
- Le fonctionnement du SI est-il **performant, conforme et durable** ?

Comment ?



1. La gouvernance des systèmes d'information

Alignement stratégique ⇒

Les priorités SI doivent répondre aux **besoins métiers**.

Utilisation efficace des ressources ⇒

Gérer le **budget IT**, le parc matériel, les compétences et les licences de manière optimale.

Gestion des risques IT ⇒

Identifier les **cyber-risques**, vulnérabilités, dépendances critiques (méthodologie EBIOS, MEHARI...).

Conformité ⇒

Respect des normes (ISO 27001), des lois (RGPD, LPM, SOX...), des politiques internes

Performance et amélioration continue ⇒

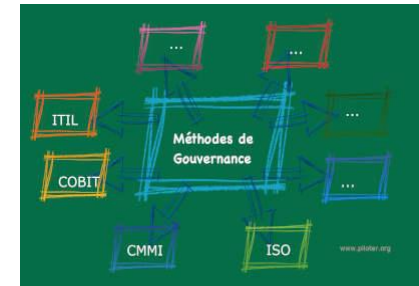
Mettre en place des **KPI**, faire des revues périodiques, utiliser les **retours d'audit** pour s'améliorer.



1.1. Les référentiels de gouvernance SI

Plusieurs **cadres méthodologiques** soutiennent cette gouvernance :

- **COBIT** (Control Objectives for Information and related Technology) – pour structurer la gouvernance SI.
- **ITIL** – pour la gestion des services IT.
- **ISO/IEC 27001** – pour la gestion de la sécurité de l'information via un SMSI.
- **TOGAF** – pour l'architecture d'entreprise.

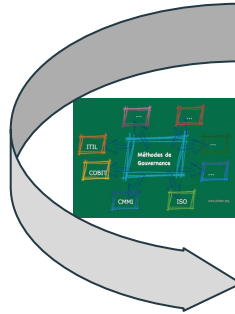


Ces référentiels fournissent un **langage commun**, des **indicateurs**, des **processus standardisés** et des **bonnes pratiques**.

1.2. Relation entre gouvernance SI et audit des SI

L'**audit des SI** est à la fois :

1. **Un outil de contrôle** : il permet d'évaluer si la gouvernance SI est effectivement mise en œuvre et suivie.
2. **Un outil d'aide à la décision** : il fournit à la direction des éléments objectifs pour piloter le SI.
3. **Un vecteur d'amélioration continue** : il identifie les écarts, les non-conformités, les zones de risque, et propose des plans d'actions.



Le lien est circulaire :

- La **gouvernance** définit les **règles, structures et processus** du SI.
- L'**audit** évalue si ces éléments sont **respectés, efficaces et pertinents**.
- Les **résultats d'audit** alimentent la **gouvernance** pour ajuster les politiques, renforcer les contrôles ou réorienter les investissements.

Cas d'application

2. Rôles et responsabilités

Une gouvernance efficace des SI repose sur une **définition claire des rôles et responsabilités**.

La sécurité de l'information n'est pas uniquement une affaire technique ; c'est une **démarche organisationnelle transversale** qui mobilise plusieurs acteurs à différents niveaux de l'entreprise.



	Responsable	Approbateur	Consulté	Informé
	Membre d'équipe 1	Membre d'équipe 2	Membre d'équipe 3	Membre d'équipe 4
Tâche 1	C	R	A	I
Tâche 2	AR		I	C
Tâche 3	C	I	R	A
Tâche 4	I	C	A	R

FICHE DE POSTE CHEF DE PROJET EXEMPLE

PROFIL

- Titre : Chef de projet IT
- Direction : Direction des projets IT
- Niveau hiérarchique : Cadre
- Rattachement hiérarchique : Directeur de projets IT
- Rattachement fonctionnel : Direction générale

MISSIONS

- Définition et gestion du projet
- Coordination des équipes
- Communication avec les parties prenantes

COMPÉTENCES

- Compétences en gestion de projet
- Compétences en communication
- Compétences en leadership

FORMATION ET EXPÉRIENCE

- Bac +5 en gestion de projet, ingénierie informatique, ou autre discipline connexe
- Expérience de 5 ans minimum dans la gestion de projets informatiques

COMPÉTENCES SPÉCIFIQUES

- Compétences en développement informatique
- Compétences en test
- Compétences en déploiement
- Compétences en sécurité informatique
- Compétences en gestion de bases de données
- Compétences en réseau

2. Rôles et responsabilités

Une gouvernance efficace des SI repose sur une **définition claire des rôles et responsabilités**.

DSI – Pilote l'architecture globale du SI. Garantit la **disponibilité, cohérence, performance et évolutivité** du SI. Veille à l'**alignement du SI avec les objectifs métiers**.

RSSI – Élaborateur de la **politique de sécurité**, pilote sa mise en œuvre. Coordonne les plans de **gestion des risques**, sensibilise les collaborateurs, surveille les incidents de sécurité.

Auditeur SSI Intervenant externe ou interne chargé d'**évaluer la conformité**, d'analyser les risques résiduels, d'**identifier les écarts** et de **proposer des plans d'amélioration**.

Audité (responsable métier ou technique) Fournit les **informations demandées par l'auditeur**, collabore à la démarche, et **met en œuvre les actions correctives** post-audit. Il est **acteur du changement**.

2. Rôles et responsabilités

Exemple :

Lors d'un **audit d'accès logique**, le **DSI** explique les processus IT en place, le **RSSI** fournit la politique de gestion des identifiants, les **équipes techniques** démontrent la configuration des annuaires, et les **audités** valident le fonctionnement au quotidien.

L'**auditeur** identifie alors des comptes inactifs non désactivés, ce qui génère un **risque de compromission**.



2. Rôles et responsabilités

Importance de la clarté des responsabilités dans un audit SSI

1. **Garantir la traçabilité** des actions : Qui fait quoi, quand et comment ?
2. **Responsabiliser les acteurs** : Un audit sans interlocuteur identifié perd son efficacité.
3. **Favoriser l'objectivité de l'évaluation** : L'auditeur ne peut juger que ce qui est attribué clairement.
4. **Renforcer l'amélioration continue** : Chaque acteur doit pouvoir s'approprier les résultats et piloter les mesures correctives.



Une **bonne gouvernance des SI** repose d'abord sur une **clarté organisationnelle**. Chaque acteur doit **connaître ses responsabilités**, les exercer, et rendre compte.

C'est l'**interaction coordonnée** entre tous ces rôles qui permet à l'audit d'**évaluer objectivement** le dispositif en place, et de générer de la **valeur organisationnelle durable**.

3. Le système de management de la sécurité

Le **Système de Management de la Sécurité de l'Information (SMSI)**, tel que défini par la norme **ISO/IEC 27001**, est un **cadre de gouvernance intégré** qui permet à une organisation de :

- Identifier et gérer les **risques liés à l'information** ;
- Définir une **politique de sécurité cohérente** avec les enjeux métiers ;
- **Surveiller et améliorer** en continu l'efficacité de ses dispositifs.

Contrairement à une vision trop technique, le SMSI **ne se limite pas à la cybersécurité ou à l'IT** :

Il **s'articule avec l'ensemble du système d'information (SI)**, qui englobe **les processus métiers, les données, les technologies, les personnes et les procédures**.

C'est un levier transversal de pilotage

3. Le système de management de la sécurité

Le **Système de Management de la Sécurité de l'Information (SMSI)**, bien qu'axé initialement sur la **sécurité**, s'inscrit dans un **cadre plus large de management des Systèmes d'Information**.

Il constitue un **socle structurant pour garantir la cohérence, la performance, la conformité et la résilience** des SI.

Pour l'auditeur:

C'est à la fois un **référentiel d'analyse**, un **cadre de vérification** et un **levier d'amélioration**.

Le **cadre de sécurité** est l'ensemble des **règles, politiques, procédures, normes et référentiels** qui définissent la **gouvernance** et les **principes directeurs** de la sécurité au sein d'une organisation.

ISO/IEC 27001/27002 : système de management de la sécurité (SMSI)

ISO/IEC 22301 : Systèmes de management de la continuité d'activité

COBIT / ITIL : gouvernance et gestion des services IT

EBIOS RM / ISO 31000 : gestion des risques

NIST CSF : cadre de cybersécurité opérationnelle

4. Relation entre gouvernance, Conformité et Audit

Gouvernance

La gouvernance SSI est le cadre global qui dirige et contrôle les systèmes d'information et les mesures de sécurité pour soutenir les objectifs stratégiques de l'organisation.

Elle inclut la définition des politiques, la gestion des risques, la conformité et l'audit.

Conformité

La conformité consiste à s'assurer que les systèmes d'information et les mesures de sécurité respectent les lois, réglementations et normes applicables.

La conformité est une partie intégrante de la gouvernance SSI et est essentielle pour éviter les sanctions légales et réglementaires.

Audit

L'audit est le processus d'évaluation de l'efficacité des mesures de sécurité et de la conformité aux politiques et réglementations.

L'audit est un outil clé de la gouvernance SSI, car il permet d'identifier les lacunes et les faiblesses et de recommander des améliorations.

Conclusion

La gouvernance SSI repose sur un équilibre entre responsabilités claires, cadre structuré (SMSI), et processus d'audit rigoureux. Le rôle de chaque acteur est complémentaire et essentiel pour créer une culture de sécurité durable.

Un bon pilotage stratégique de la sécurité repose sur **l'intégration de l'audit, la formalisation des règles, et la responsabilisation des parties prenantes.**

Par ailleurs, **l'audit de sécurité** s'impose comme un levier incontournable de cette gouvernance. Il permet de **vérifier la conformité, de détecter les failles et d'améliorer en continu** les dispositifs de sécurité.

En complément des dispositifs organisationnels, les rôles bien définis de chaque acteur (RSSI, DSI, auditeur, audité, utilisateurs) sont essentiels pour garantir l'efficacité globale du système.

Ce chapitre a ainsi permis de poser les fondements d'une sécurité gouvernée, intégrée et proactive.

Les prochains chapitres approfondiront les méthodes d'audit, l'analyse des risques, et les outils techniques, pour construire une démarche complète et opérationnelle de sécurisation du SI.